

STUDIO DI UNA CAMPAGNA PHISHING

OBIETTIVO

Creare una campagna phishing a scopo di studio per analizzarne e comprenderne meglio le caratteristiche che la rendono efficace.

SVOLGIMENTO

Ho voluto ricreare e analizzare la campagna phishing bancaria a danno dei clienti. Ho fatto creare il corpo del testo all'IA, nel mio caso ho usato GEMINI, indicando chiaramente nel prompt che è a scopo di studio. Ho poi specificato nel prompt il destinatario e questo è stato il risultato finale:

Da: Sicurezza Clienti <sicurezza@banca-alfa-notifiche.example>
A: roberto.ferrara@email.example
Oggetto: URGENTE: Limitazione cautelativa del conto corrente per Roberto Ferrara

Gentile **Roberto Ferrara**,

La informiamo che il nostro sistema di monitoraggio automatico ha rilevato un tentativo di accesso anomalo ai suoi servizi di Home Banking da un indirizzo IP non autorizzato.

A titolo precauzionale e per garantire l'integrità dei suoi fondi, abbiamo temporaneamente limitato le operazioni in uscita e l'uso delle carte collegate al suo profilo. Per ripristinare la normale operatività e confermare la titolarità del conto, è necessario completare la procedura di verifica guidata entro 24 ore dal ricevimento della presente e-mail:

[Sblocca il Conto Online ed Effettua la Verifica]

In caso di mancata risoluzione entro i termini indicati, i servizi dispositivi rimarranno sospesi in attesa di accertamenti in filiale.

Distinti saluti,
Servizio Prevenzione Frodi - Istituto di Credito Alfa

ANALISI

In questa mail, apparentemente mandata da un istituto bancario, si avverte la vittima di un presunto accesso anomalo all'Home Banking, la quale ha portato alla limitazione temporanea sia al profilo sia all'uso delle carte. Quindi si richiede al cliente di accedere ad un link di verifica per riattivare il conto.

Nella mail si possono individuare varie tattiche e tecniche riconducibili all'ingegneria sociale:

INDICATORI DI RISCHIO E VALUTAZIONE TECNICA (RED FLAGS)

- **Il principio d'urgenza di Cialdini:** La richiesta di fare tutto entro 24 ore o si rischia la sospensione fa riferimento al principio d'urgenza, molto utilizzato in quest'ambito perché la paura di perdere qualcosa cancella la lucidità delle persone.
- **Spear Phishing e Personalizzazione:** La vittima viene chiamata per nome e cognome (Roberto Ferrara), trattandosi di Spear Phishing, quindi un attacco personalizzato che porta il cliente a fidarsi più facilmente.
- **Leva dell'Autorità:** L'attacco proviene da un finto istituto bancario facendo leva sul principio di autorità. L'essere umano tende a ubbidire di più se l'ordine arriva da una persona o da un ente superiore. La scritta finale "Servizio prevenzione frodi" dona una certa credibilità al messaggio.
- **Link malevolo:** L'uso di un link malevolo serve per dirottare la vittima su un sito clone di quello ufficiale, dove la vittima scriverà i dati di accesso e verranno rubati dall'attaccante.

LINEE GUIDA E BEST PRACTICES

Prima di agire secondo la notifica della mail è sempre importante prendersi un momento per riflettere, soprattutto se è richiesta una certa urgenza, poiché è molto spesso un segnale della natura malevola della mail. Quindi importantissimo leggere bene la comunicazione e analizzarla:

- Controllare il dominio del mittente se effettivamente coincide con quello ufficiale.
- Evitare di accedere tramite link e fare un controllo diretto tramite app o tramite URL ufficiale. Si può anche fare una chiamata diretta alla banca per controllare la veridicità di quella mail.
- Le banche in generale non mandano mai link di verifica account e non richiedono mai esplicitamente password o username del profilo.

CONCLUSIONE

Al giorno d'oggi gli attacchi phishing sono sempre più frequenti e sempre più convincenti grazie anche all'avvento delle IA, che hanno ridotto enormemente l'errore umano permettendo la scrittura di messaggi perfetti in qualsiasi lingua oltre che credibili. Per questo è importantissimo il training delle persone per quanto riguarda l'ingegneria sociale, i suoi principi e meccanismi, e tenersi informati sulle tecniche utilizzate dai cybercriminali.